

CycloneDX is a “lightweight” standard for SBOMs, “designed for use in application security contexts and supply chain component analysis.”

- **OpenChain ISO/IEC 5230:** This is the international standard for open source licence compliance. This specification can be used to strengthen varied business use cases throughout the software supply chain, such as procurement and outsourcing activities, or due diligence for mergers and acquisitions (M&A) activity.
- **SPDX:** The Software Package Data Exchange (SPDX) is an international open standard (ISO/IEC 5962:2021) for “communicating software bills of material information, including components, licence copyrights, and security references.”
- **SWID:** Software identification (SWID) tags (defined by the ISO/IEC 19770-2:2015 standard) contain identifying information about the specific release of a software product, helping organisations track the software that’s installed on devices.

How SBOMs protect the software supply chain

Nearly two-thirds (62 per cent) of organisations have been impacted by software supply chain attacks in the past 12 months, as found in the *Anchore 2022 Software Supply Chain Security Report*. This means that software companies are both subject to and passing along vulnerabilities in their code, highlighting the need to identify all components in use.

Developers must know the origin of the components they’re using from upstream within the software supply chain. They must also identify components being passed along further downstream in the software supply chain, such as through a software development kit (SDK), operating system, or other modules that customers use to build applications.

By identifying components and their associated licences, an SBOM provides a clear format to track and communicate this information. Additionally, in the event that one of the components has a vulnerability, having this information immediately at hand will help facilitate rapid remediation. When this information isn’t readily available, development teams can be left scrambling to identify whether or not they’re impacted by a vulnerable component (as was commonly the case with Log4j), wasting valuable time that could better be used for fixing the issue.

SBOMs as part of software composition analysis

The creation of accurate, current SBOMs happens as part of a comprehensive software composition analysis (SCA) program. SCA is the process of automating visibility into the use of open source software and other third-party content, supporting application security, risk management, and licence compliance.

SCA can discover and track all OSS and the associated licences, and then create an SBOM based on those findings. It can also help create and enforce policies, monitor for

security vulnerabilities, and integrate open source code scans into the build environment.

The automation that’s inherent in SCA is critical for staying up-to-speed with dynamic development environments. Static audits simply can’t keep up with the pace, as new vulnerabilities occur daily. SCA’s automated tracking helps developers stay focused on what they do best: creating great code.

Best practices for creating and maintaining an SBOM

Protecting the use of open source software is aided by a “shift-left” approach, in which compliance and security risks are addressed early and often as part of the development process. This is fundamental to the ability to continue developing software, without delaying releases.

An open source program office (OSPO) can be instrumental in establishing policies about the use of open source. The OSPO can also centralise efforts to identify and mitigate risks related to open source, including managing the creation and maintenance of an SBOM.

SBOM standards (such as SPDX, identified above) can help clarify what

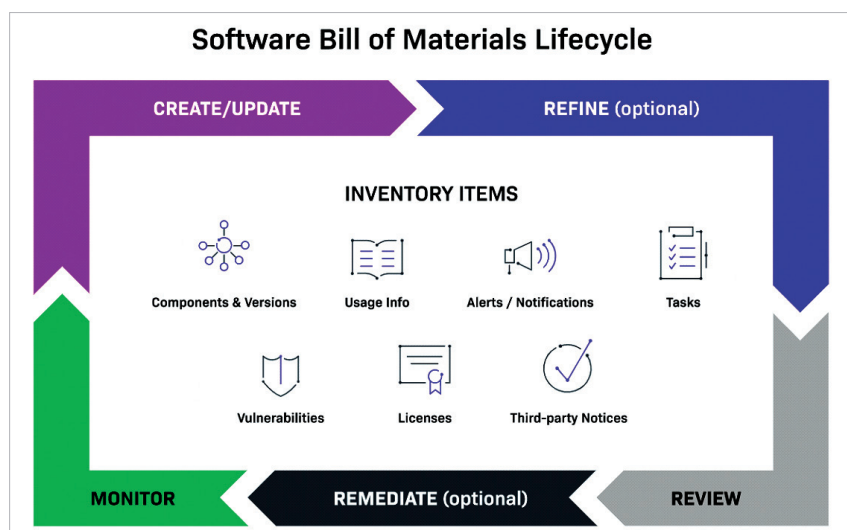


Figure 2: The software bill of materials life cycle (Source: Revenera)